Software Security 2026/2027

Exercise

Introduction

Cyber Security and Resilience | Master
Gerald Dißauer, Thomas Zefferer
WS-2026/2027

Handling Instructions:

- **Not for publication**
- Distribution on a strict need-to-know basis
- Not to be released outside of the information stakeholders

Goals

- 1 Deliverable & presentation,
- 4 Tasks under **1 consolidated exercise** included in the 1 deliverable
- 2 Discussion-topics (each by Lecturer)

- Apply lecture contents in practice
- Learn how to ensure the security of software
- Focus: selected phase in secure software lifecycle
  - We do not want you to dig into details around of selected aspects
  - We want you to see the big picture from source code review perspective

- We do this by means of testing and presenting your findings

Task 1

- 10 credits
- You develop a (small) PKI using LLM e.g., ChatGPT or Mistral *(on purpose!)*
- You evaluate the generated source code using a tool of your choice
- You identify potential flaws/vulnerabilities/weaknesses in the source code
- You consolidate your findings and present them

General Overview

- Used tools: openssl, linux
- Use VM-environment (e.g., VirtualBox) and your favourite Linux

Task 1 | cont´d

/computer science & security /fh/// st.pölten

Objective: Understand the process of the certificate lifecycle *(creation, signing, verification)* by implementing a simple CA and self-signed certificate/s: even group nr: RSA 4096 (or higher), odd group nr: ECDSA using secp256 curve *(or comparable alternative)*, hash: SHA-256

(1) Generate a root CA´s private key and self signed certificate (C: AT, CN:CA_GROUP_NR, root certificate filename: ca.crt, key file name: ca.key, validity 10 years)

(2) Create a simple web servers private key and certificate signing request (CSR) (same es above besides: certificate filename: server.crt, key file name: server.key, validity: 2 years)

(3) Sign the web server´s CSR with the root CA´s private key to issue a certificate

(4) Verify the web server´s certificate against the root CA´s certificate

(5) Provide shell scripts which do the above (create_[ca|csr|cert].sh, verify_cert.sh])

(6) Explain each single step performed as inline comments

(7) Conduct testing using a testing tool of your choice to identify flaws/vulnerabilities

Task 2

/computer science & security

/fh/// st.pölten

- 10 credits
- You are a security tester of a security consulting firm

- Your company..
  - ..owns the No. 1 Cyber Security Lab
  - ..conducts source code reviews including *(static)* testing of publicly available source code
  - ..identifies flaws/vulnerabilities in publicly available source code
  - ..develops CVEs and CWEs from the findings

Your mission: „Identify at least one CVE or at least one CWE“

Task 2 | 4 Objectives

/computer science & security

/fh/// st.pölten

Objective 1 | Source Code

Identify suitable source code *(snippets)* publicly available to achieve mission success

Objective 2 | Tool selection

Select a test tool *(proposal list to be included in this slides)* and perform the tests

Objective 3 | Findings and report creation *(report = presentation!)*

Clarify your observations and document them, briefly. Derive one CVE and/or CWE *(or create a conjunction to existing CWE)*. Explain the vulnerabilities and justify both your decision and your findings as well. Create a presentation.

Objective 4 | Summary of observations about selected tool

Give a short introduction to using your selected tool to the class. Highlight your discovered advantages and disadvantages as well. Include your findings in the above mentioned presentation.

Task 3

- 10 credits
- You are a security tester of a security consulting firm

- Your company..
  - … conducts testing on the reference implementation of the EUDIW
  - Reference: https://github.com/orgs/niscy-eudiw/repositories

Task 3 | 4 Objectives

/computer science & security

/fh/// st.pölten

Objective 1 | Source Code

Identify suitable source code *(snippets)* of the EUDIW reference implementation

Objective 2 | Tool selection

Select a test tool *(proposal list to be included in this slides)* and perform the tests

Objective 3 | Findings and report creation *(report = presentation!)*

Clarify your observations and document them, briefly. Derive one CVE and/or CWE *(or create a conjunction to existing CWE)*. Explain the vulnerabilities and justify both your decision and your findings as well. Create a presentation.

Objective 4 | Summary of observations about selected tool

Give a short introduction to using your selected tool to the class. Highlight your discovered advantages and disadvantages as well. Include your findings in the above mentioned presentation.

Task 4
Encoding and Decoding

/computer science & security

/fh/// st.pölten

- 15 credits

Use an AI tool (e.g., ChatGPT or Claude) to create two C programs that provide the following functionality:

Program 1: Encoder (task41enc.c)

- Prompt the user to enter a message.
- Prompt the user to enter a password.
- Encrypt the message and save it to the file text.ct in Base64-encoded format.

Program 2: Decoder (task41dec.c)

- Read text.ct and decrypt its contents using a password entered by the user.
- Display the decrypted message.

Cryptographic Algorithms to Use

- **PBKDF2 with HMAC-SHA256** to derive an AES key from the password (note: PBKDF2 requires a salt).
- **AES-256 in GCM mode** for encryption (note: GCM requires an IV and generates an authentication tag in addition to the ciphertext).

Task 4
Requirements

/computer science & security

/fh/// st.pölten

Requirements

- Use the OpenSSL library for all cryptographic algorithms and operations. If necessary, install missing components using apt and sudo.
- Create a Makefile to build both programs.
- Move duplicated code and shared functionality into a common module; use function pointers where appropriate.
- Suitable libraries and headers include: stdio.h, stdlib.h, string.h, openssl/evp.h, and openssl/rand.h.
- Declare and initialize all required variables (key, IV, salt, plaintext, ciphertext, and lengths).
- Generate a random salt, derive the key using PBKDF2, perform the encryption, and write the IV, salt, and encrypted message to the output file.
- Perform cleanup after each step: free allocated memory, securely erase sensitive data, and close open files.
- Provide a shell script or Makefile to compile both programs.

Task 4
Procedure

/computer science & security

/fh/// st.pölten

Procedure

- Formulate a precise prompt for the AI tool that includes the complete specification.
- **You can use uploaded package as starting point**
- Verify that all requirements have been met and ask targeted follow-up questions if anything is missing.
- Test the code, including using the OpenSSL command-line tool for testing and identify weaknesses. Optimize the source code with AI.

Understand the generated code well enough to explain your learning outcomes to the class.

!!! Run the tests only in an isolated test environment using non-sensitive data !!!

Task 4
CWE and CVE Overview

/computer science & security /fh/// st.pölten

Overview about potential Weaknesses and Vulnerabilities – basis to show possible CVE/CWE in Code example (see: eCampus)

- CWE-120: Buffer Copy without Checking Size of Input
  Missing buffer size checks
  NVD Example: CVE-2020-5133
- CWE-400: Uncontrolled Resource Consumption
  Resource exhaustion while parsing permission declarations, potentially causing a boot loop or local denial of service.
  NVD Example: CVE-2023-21090
- CWE-476: NULL Pointer Dereference
  Improper handling of failed allocations or API calls
  CVE-2022-40476
- CWE-457: Use of Uninitialized Variable
  Use of uninitialized values
  CVE-2026-11137

7 Proposed Tools | List Every Group Different Tool

/computer science & security /fh/// st.pölten

Include your selected Tool (First Come first serve in Etherpad)

- ☐ SonarQube
- ☐ Semgrep (e.g., in conjunction with LLM)
- ☐ Infer
- ☐ ESLint
- ☐ Review NB
- ☐ CodeQL
- ☐ DeepCode Snyk
- ☐ SpotBugs
- ☐ Veracode
- ☐ BurpSuite
- ☐ OWASP ASST or OWASP Mutillidae II
- ☐ Valgrind
- ☐ any LLM (such as ChatGPT, Mistral, etc.)

Select one Tool for Source Code Analysis
Others possible some of those support/use AI

Containing Your Efforts

/computer science & security /fh/// st.pölten

- You will work in 5 groups
- It is up to you how you organize yourself group-internally
- All group members receive the same number of points depending on the group's performance
  - For the four tasks (i.e., task 1, task 2, task 3, task 4)
  - Working source code
  - Argumentation on selected tool
  - Identified CVE/CWE
  - Presentation of results *(in class)*
- Approach ca. 30min for your presentation

Example Source Code

/computer science & security /fh/// st.pölten

- https://github.com/PuneethReddyHC/online-shopping-system-advanced
- https://codeastro.com/ecommerce-site-in-php-with-source-code/
- https://github.com/bigprof-software/online-invoicing-system/archive/3.1.tar.gz
- https://github.com/coder-rukon/Hospital-Management-System-php-project
- https://github.com/ajaybgunjal/University-Management
- https://github.com/nofaralfasi/PHP-Online-Store
- https://github.com/haxxorsid/stock-management-system
- https://github.com/ScaleSec/vulnado
- https://github.com/Podvodila/parkour

Expected Results

- 1 presentation consolidating the 4 mentioned tasks herein
- 1 Presentation consolidating the 4 mentioned tasks herein
- Your learning outcomes in terms of:
  - using AI to generate source code
  - using a testing tool to evaluate the source code
  - benefits/shortcomings of your selected tool

Discussion
AI in Knowledge Acquisition

/computer science & security

/fh/// st.pölten

AI and Knowledge Acquisition

- What do I actually still need to learn and know myself these days?
  - Syntax?
  - APIs?
  - Algorithms?
  - Software architecture?
  - Security fundamentals?
  - Cryptography?

Discussion | cont´d
AI in Knowledge Acquisition

/computer science & security

/fh/// st.pölten

AI and Knowledge Acquisition

- What do I need to know to be able to assess whether an AI-generated answer is correct in the first place?
- How can AI support me in learning?
  - As a tutor
  - Providing explanations at different levels of complexity
  - Generating exercises
  - Taking opposing positions
  - Testing my understanding

Discussion | cont´d
AI in Knowledge Acquisition

/computer science & security

/fh/// st.pölten

AI and Knowledge Acquisition

- The danger of the “illusion of competence”:
  - I can use AI to produce a working solution — but do I actually understand it?
  - How can I recognize gaps in my own knowledge?
- A potential risk: AI becomes the sole repository of know-how and is suddenly no longer available.
  - What happens in the event of an outage, a provider switch, a price increase, or regulatory restrictions?
  - Which skills and knowledge must therefore be deliberately retained within the company or by the individual?

Discussion | cont´d
AI in Knowledge Acquisition

/computer science & security
/fh/// st.pölten

AI and Knowledge Acquisition

- **University education in the age of AI — the students' perspective:**
  - Do exams still make sense?
  - Do theses and dissertations still make sense?
  - Do programming exercises still make sense?
  - Should AI be allowed when completing exercises?
  - Should there be assignments that must be completed both with and without AI?
  - Should the final result or the problem-solving process be assessed?
  - How can we determine what someone is actually capable of doing independently?
  - What should teaching ideally look like in the age of AI?
- Best practices for using AI to acquire knowledge

Topics for 2nd Discussion

Given by other Lecturer

Discussion | cont´d
AI in Business

/computer science & security

/fh/// st.pölten

AI in Business

- **AI in Business**To what extent is the use of AI beneficial or necessary for a company?
- Will companies eventually face a competitive disadvantage if they do not use AI?
- Conversely, can adopting AI too early or without adequate controls become a risk?
- How should confidential data be handled?
  - Trade secrets
  - Customer data
  - Personal data
  - Source code

Discussion | cont´d
AI in Business

/computer science & security

/fh/// st.pölten

AI in Business

- Dependence on individual AI providers:
  - Vendor lock-in
  - What happens if a service is discontinued or becomes significantly more expensive?
  - What happens if a model's behavior changes following an update?
- What will the world of work look like in five years?
  - Which developer roles will disappear or change?
  - Will small teams suddenly be able to build software that currently requires 50 people?
  - Will this also make small groups of attackers significantly more capable?
- Which tasks can be delegated to AI, and which cannot?
  - Routine tasks
  - Security-critical decisions
  - Architectural decisions
  - Approvals and sign-offs

Discussion | cont´d
AI in Business

/computer science & security

/fh/// st.pölten

AI in Business

- A potential risk: AI becomes the sole repository of know-how and is suddenly no longer available.
- **Governance**
  - Does a company need an AI policy?
  - Which models and tools should employees be allowed to use?
  - Who should make that decision?
  - Should the use of AI be traceable and logged?
- **Liability and Accountability**
  - Can someone defend themselves against responsibility for an error by saying, “The AI did it”?
  - Who must review and approve AI-generated output?

Timeline

- **Thu, 11/03/2026** 23:55, delivery via eCampus
- **Wed, 11/04/2026** presentation beginning from 13:50 – 17:55

ca. 30 minutes per group (presentation)

Questions

